

Layered Authorization: Enterprise Floor, Mission Edge

Oct 7, 2026 · @Adam

Summary

This proposal extends enterprise ICAM governance to mission-specific access decisions. Its principal architecture claim, adopted from the independent architecture and security assessment:

Enterprise ICAM remains the authoritative source of enterprise identity, authentication, and access boundaries. Mission authorization services may impose additional restrictions within those boundaries. A governed authorization composition capability produces the effective decision, which is enforced at every protected resource boundary. No mission policy, fallback mechanism, or enforcement point may bypass enterprise restrictions or its own required controls.

The one-line version: **the STS proves who you are, enterprise ICAM decides what you are cleared for, and the mission decides what that means here, within limits ICAM sets.**

Revision note. This revision addresses the independent architecture and security assessment of 7 October 2026, which recommended approving the layered pattern in principle and chartering an integrated security proof of concept before production. The assessment's findings have been accepted and incorporated; a summary of changes appears in the revision history appendix. A follow-up reassessment identified fourteen further findings; nine are resolved in this revision and the rest are tracked for resolution.

Why now

Enterprise ICAM has already done the hard foundational work: authentication is centralized and authorization decisions are externalized from applications. What has changed is demand. Mission-specific rules, such as position-based access, workflow state, and data release conditions, are multiplying faster than any enterprise-wide entitlement catalog can reasonably absorb. That is a structural limit of serving every

mission's fine-grained needs from one central catalog, not a shortcoming of the team that runs it. At the same time, our developer platform relies on a bespoke auth proxy that combines token handling and access logic in one unstandardized component.

The question is not whether mission-level rules will exist; they already do, scattered across applications and workarounds. The question is whether they exist under enterprise ICAM governance or outside it.

Standards alignment

The pattern is designed to align with the following frameworks and specifications. Alignment is a design intent; conformance and control effectiveness will be demonstrated through the proof of concept, control assessment, and authorization, not asserted by this document.

- **NIST SP 800-207, Zero Trust Architecture:** per-request decisions by policy decision points, enforced by policy enforcement points.
- **NIST SP 800-207A, Zero Trust for cloud-native applications:** workload identity, service-to-service enforcement, and east-west traffic control.
- **NIST SP 800-162, Attribute Based Access Control:** access derived from governed, trusted subject, resource, and environment attributes.
- **NIST SP 800-63-4, Digital Identity Guidelines:** authentication assurance, federation, session binding, and re-authentication.
- **NIST SP 800-53 Rev. 5:** a preliminary control mapping appears later in this document.
- **OAuth 2.0 and OIDC profiles:** RFC 9068 access tokens, RFC 8725 and RFC 9700 security practices, RFC 8693 token exchange, and RFC 9470 step-up challenges.
- **OpenID AuthZEN Authorization API 1.0:** an approved OpenID Foundation Final Specification defining single and batch evaluations, authorized subject, resource, and action search APIs, and discovery. Native policy query plans and data store filter translation are separate contracts. Response context may convey obligations and step-up information; this design defines their semantics and mandatory enforcement behavior.

The design maps to the logical functions of NIST SP 800-207 without requiring a separate appliance for each:

SP 800-207 function	In this design
Policy engine	The enterprise and mission decision points, whose results the composition capability combines into the effective decision
Policy administrator	The composition capability, which establishes or denies each decision path, together with the mechanisms that interrupt sessions, jobs, and subscriptions on revocation
Policy enforcement point	Tyk Gateway at ingress and the internal enforcement points
Data sources and policy information points	The enterprise STS, entitlement systems, attribute services, authoritative resource records, and endpoint posture

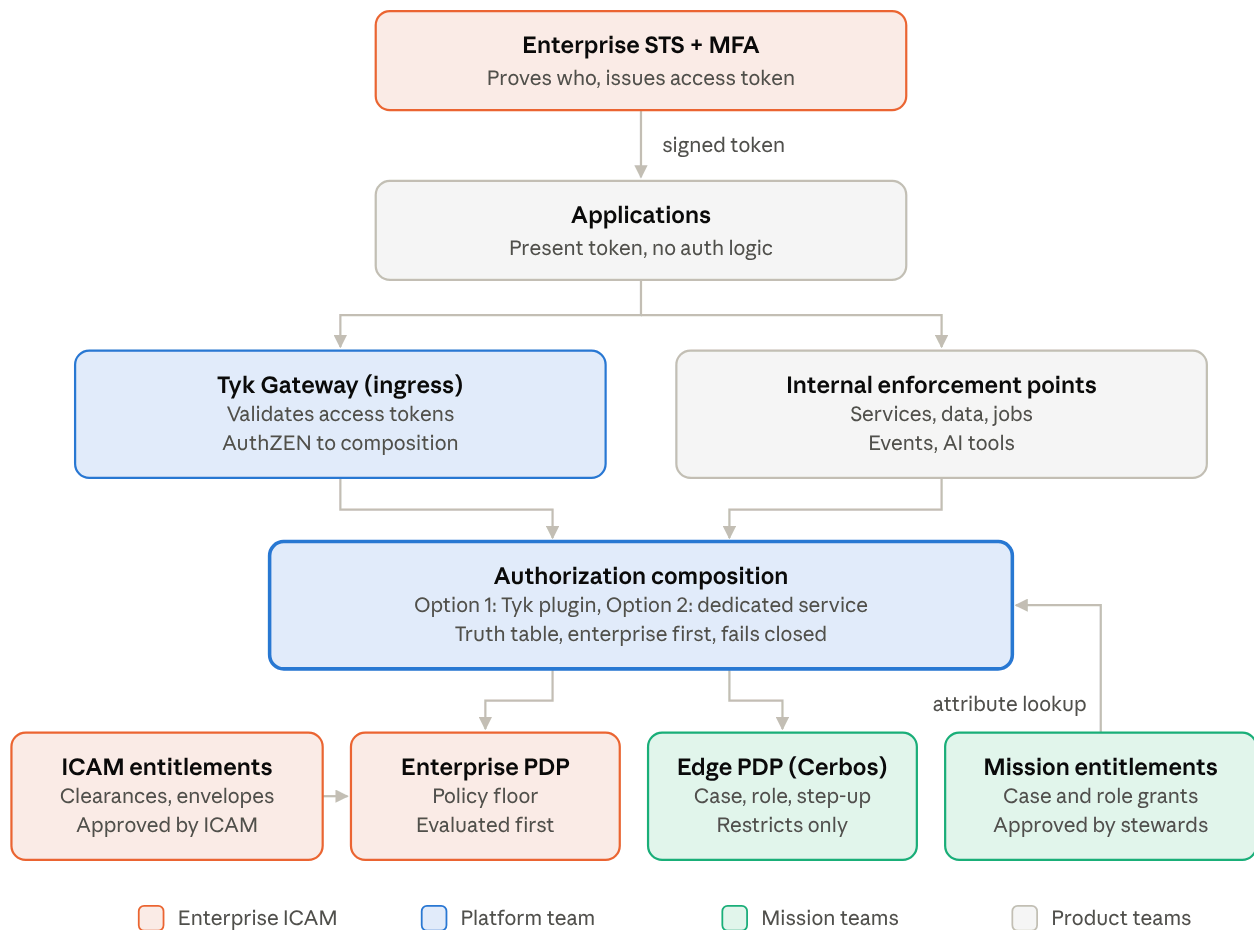
Design principles

1. **Enterprise ICAM is the floor, and the floor is authoritative.** The mission layer may add restrictions but can never grant what the enterprise denies.
2. **Enterprise ICAM governs the pattern.** ICAM approves access envelopes, the composition truth table, administrative controls, mission adoption, and promotion of attributes to the enterprise catalog.
3. **Ownership follows rate of change.** Identity, clearances, and attributes of record remain with ICAM. Mission rules are maintained by the teams closest to them, under ICAM-approved boundaries.
4. **The mission layer never authenticates.** The enterprise STS and MFA remain the only source of identity and the only place stronger proof is collected.
5. **Complete mediation.** Every protected operation passes through an enforcement point, whether at ingress, in a service, at a data boundary, in a worker, at event delivery, or at an AI tool call. Bypass paths are prohibited and tested for.
6. **One composition semantics, failing closed.** Every enforcement point obtains decisions from the same composition capability with the same deterministic truth table. Errors, timeouts, and missing coverage never produce a permit.

7. **Security attributes come from authoritative sources.** Values used in decisions are obtained from tokens, authoritative attribute services, or authoritative resource records, never from caller-supplied request content.
8. **No administrative action broadens access.** Emergency controls deny; rollbacks are validated against current restrictions and cannot expand access without independent approval; break-glass is a scoped, expiring policy exception evaluated through composition, never a bypass.

Architecture

One composition capability, many enforcement points, enterprise first



layered authorization · ingress and internal enforcement, one composition, two decision points

Tyk Gateway is the ingress enforcement point. Operations that ingress cannot see are covered by internal enforcement points in services, data access layers, workers, event delivery, and AI tool calls. Every enforcement point obtains its decision from one

authorization composition capability, which retrieves authoritative attributes, asks the enterprise decision point first, then the mission decision point, and applies a deterministic truth table. Colors show who owns each component.

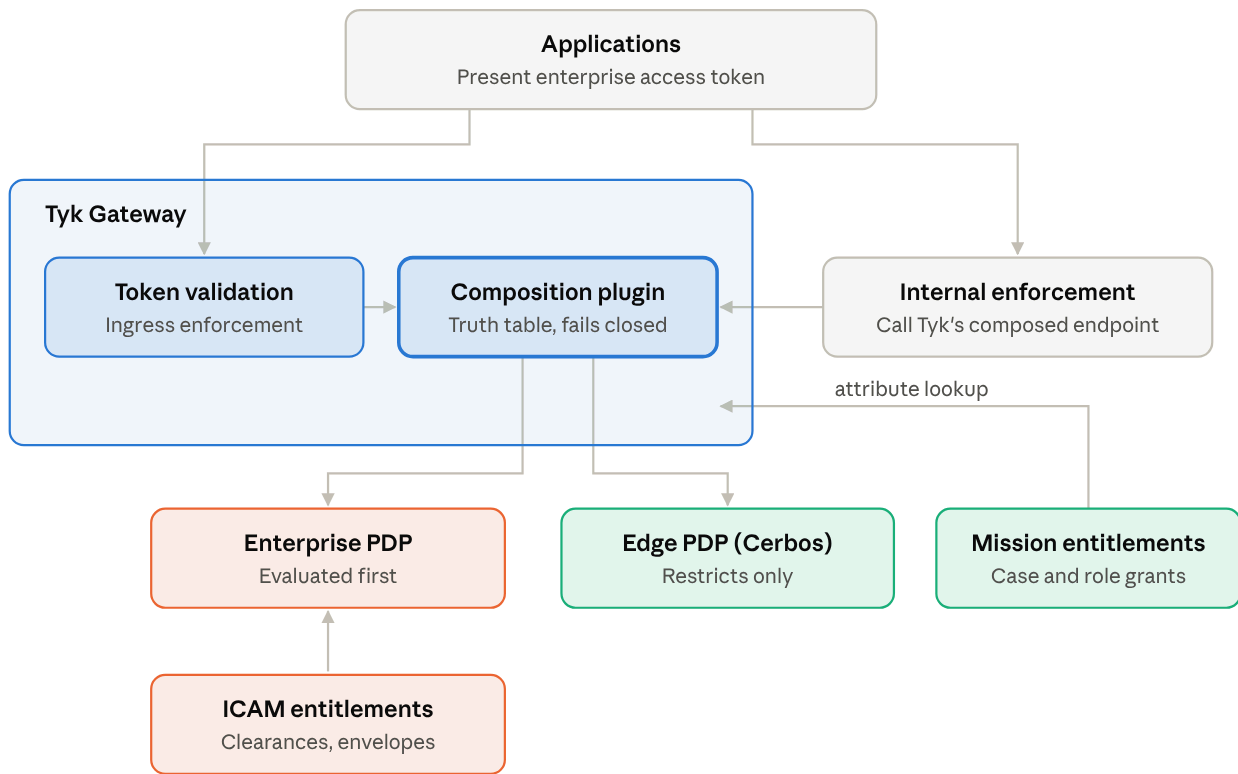
Authorization composition

Composition is the enterprise-governed function that turns two decisions into one effective decision. Two implementation options will be evaluated in the proof of concept against the same requirements.

	Option 1: Tyk composition plugin	Option 2: Dedicated composition service
What it is	A Tyk middleware plugin calls both decision points and applies the truth table inside the gateway. Tyk also exposes a composed AuthZEN endpoint that internal enforcement points call.	A small, hardened service exposes AuthZEN evaluation, batch evaluation, and a filter endpoint. Tyk and internal enforcement points each call it as a single decision endpoint.
Strengths	Fewer components to operate; lowest added latency at ingress; builds on Tyk’s supported plugin model	Isolated and small enough to test exhaustively; independent of the gateway’s release cycle; one obvious home for query planning, filter translation, obligations, and audit records
Risks to retire	Multi-decision composition in the AuthZEN plugin is not yet demonstrated; plugins are compiled per gateway version; query planning and filter translation must be built into the plugin; composition shares a failure and upgrade domain with ingress	One more service to deploy, secure, and keep highly available; an added network hop for ingress decisions

Option 1 architecture

Option 1: composition runs inside Tyk Gateway



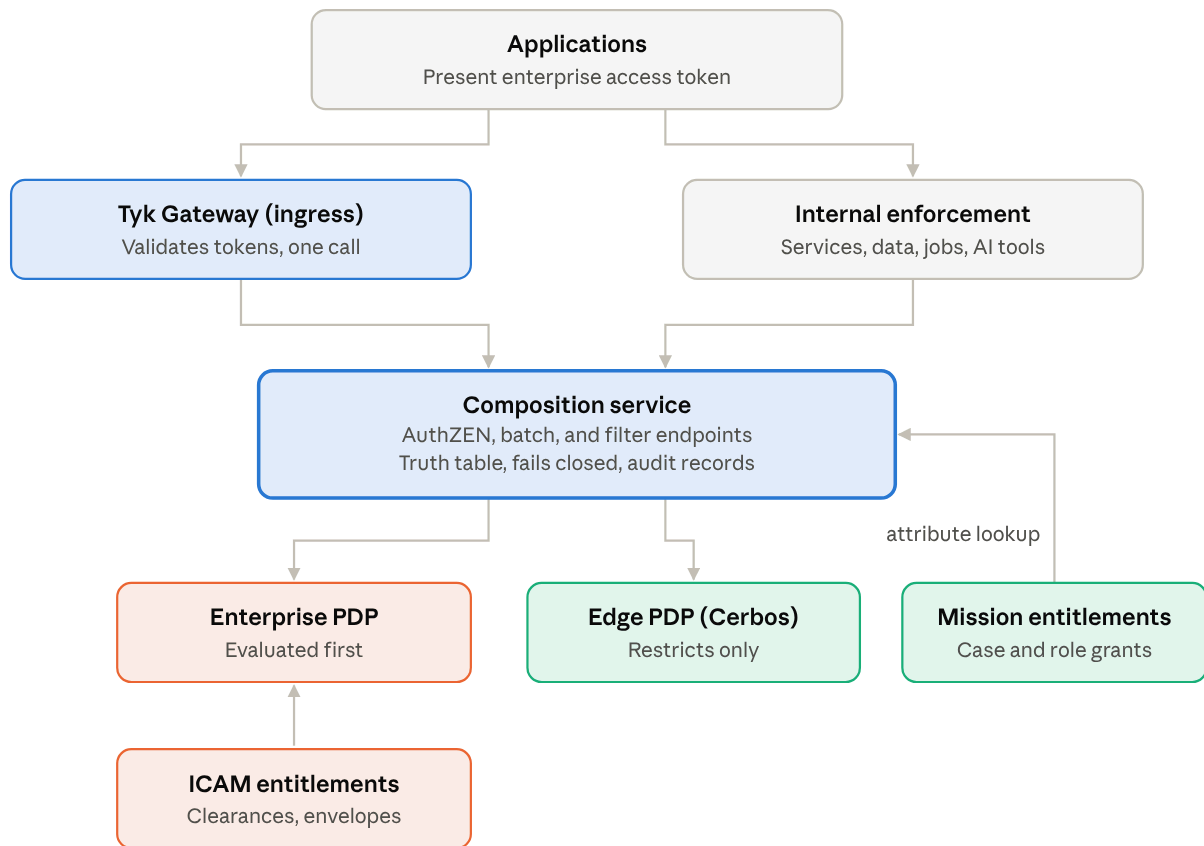
Ingress and internal enforcement points share one composition path inside the gateway.

option 1 · composition plugin inside Tyk Gateway

Composition runs as a plugin inside Tyk Gateway, after token validation. Internal enforcement points call a composed AuthZEN endpoint that Tyk exposes, so every decision passes through the gateway.

Option 2 architecture

Option 2: a dedicated composition service



Tyk and every internal enforcement point call the same isolated service.

option 2 · dedicated composition service

Composition runs as a separate, isolated service. Tyk validates tokens and makes one decision call; internal enforcement points call the same service directly, without routing through the gateway.

Selection criteria. The option selected must demonstrate, under test: full conformance to the truth table including error and not-applicable cases; support for single, batch, and collection filter decisions; the identical request binding and obligation profiles; normalized decision states with separate enforcement records; isolation sufficient for reference monitor requirements; and latency and availability within agreed objectives. Both options use the same truth table, attribute trust rules, and audit schema, so the choice does not change any other part of this design.

Composition truth table. Approved by enterprise ICAM and changeable only with ICAM approval.

Enterprise	Mission	Effective decision
Permit	Permit	Permit
Permit	Deny	Deny
Permit	Not applicable (no mission policy covers a mission resource)	Deny
Permit	Error or timeout	Deny
Deny	Not evaluated	Deny
Error or timeout	Not evaluated	Deny
Not applicable (coverage gap)	Not evaluated	Deny

Decision request binding. An authenticated connection proves which service called composition; it does not prove that the user or operation in the request is legitimate. Both composition options therefore implement one identical binding profile:

1. **The composition API is itself authorized.** Only registered enforcement points may call it, authenticated by workload identity through mTLS or sender-constrained tokens. Each registration lists the resource types and actions that enforcement point may request decisions for, and requests outside its registration are rejected.
2. **Subject evidence comes from verified tokens by default.** Every enforcement point forwards the user's access token, or a token exchanged under the delegation profile, as subject evidence. Composition validates its issuer, audience, expiry, and binding to the calling enforcement point, through sender constraint or an actor claim naming that service. An enforcement point cannot assert an arbitrary user.
3. **Trusted assertions are limited to workloads without a user.** System jobs with no end user use a short-lived assertion signed with the job's workload identity, with composition as its audience. The asserted subject is that workload's own identity and nothing else.
4. **Security context is derived server-side.** Composition derives roles, mission, tenant, policy version, and policy scope from authoritative sources. Caller-supplied values for any of them are rejected.

- 5. Resources and actions are normalized.** Resource identifiers are canonical and mission-qualified, so one object has exactly one identifier. Operations map to policy actions through the enforcement point's registration, not free text.
- 6. Every decision is bound to its request.** Each decision carries an identifier and is bound to its full tuple: subject, actor, action, canonical resource identifier and version, context, policy version, and attribute versions. The enforcement point verifies that the decision matches the exact operation it is about to execute, caches are keyed on the full tuple, and a decision for one resource cannot be replayed against another.

Obligation profile. A protected action executes only after valid enterprise and all required mission permits are bound to that action and all mandatory pre-execution obligations are satisfied. Obligations follow a versioned profile:

Element	Rule
Definition	Each obligation type has an identifier, version, schema, a mandatory or advisory classification, a timing (pre-execution, at commit, or post-action), and the enforcement capability it requires
Preservation	Composition preserves every mandatory obligation from the enterprise and mission decision points; none is dropped in composition
Merging	Identical obligations are deduplicated; compatible obligations combine to the most restrictive form, such as the union of redactions; conflicts without a deterministic resolution deny the action
Capability	Whether an enforcement point can perform an obligation is checked against its trusted registration, never its own claim. A mandatory obligation the enforcement point cannot perform denies the action
Unknown or failed	An unknown mandatory obligation, or a failed pre-execution obligation, prevents the protected action. Advisory obligations may be skipped but are recorded

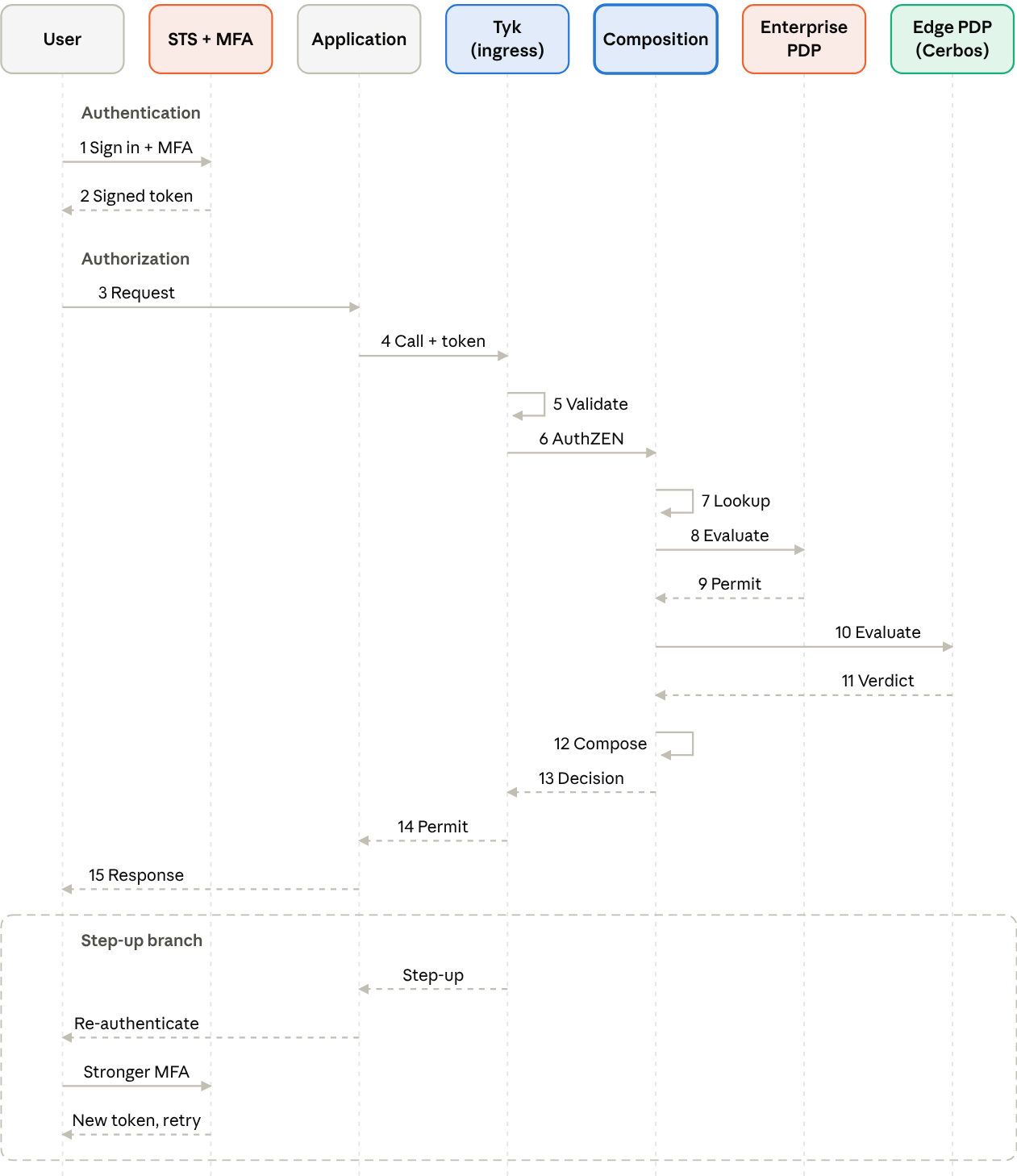
Element	Rule
Timing	Pre-execution obligations, such as redaction, watermarking, and destination checks, complete before any output leaves the enforcement point. At-commit obligations are part of the transaction. Post-action obligations, such as notifications, are used only where policy permits, and their failure is recorded and alerted
Transport	Obligations travel in the AuthZEN response context under a versioned extension that defines their meaning
Evidence	The enforcement record distinguishes the proposed permit, each obligation's completion or failure, and the action actually executed

Request flow

1. The user authenticates through the enterprise IdP with MFA. The STS issues a short-lived signed access token carrying identity, key claims, and authentication strength.
2. The application forwards the request with its token to Tyk Gateway.
3. Tyk validates the token against the token validation profile: issuer, token type, accepted algorithms, audience, expiry, and not-before.
4. Tyk requests a decision from the composition capability through AuthZEN, forwarding the validated token as subject evidence under the decision request binding profile.
5. Composition retrieves subject attributes from authoritative attribute services and resource attributes from the authoritative resource record, never from the request body.
6. The enterprise decision point evaluates first. On a deny, the mission decision point is recorded as not evaluated and the effective decision is deny.
7. On an enterprise permit, the mission decision point evaluates mission, position, case, workflow, and assurance rules.
8. Composition applies the truth table, records the outcome of each decision point, and returns the effective decision with any obligations.

9. Tyk enforces the decision at ingress. Backend operations beyond the ingress request are decided again at internal enforcement points through the same composition capability. Each enforcement point records its actual enforcement and obligation outcome under the same correlation ID.

One authentication, one composed decision, enterprise first



sequence · authentication, composed authorization, step-up branch

Solid arrows are requests and dashed arrows are responses. An enterprise deny at step 9 ends evaluation; the mission decision point is recorded as not evaluated. A step-up result sends the user back through the enterprise STS using the step-up protocol, and the

retried request is fully re-evaluated from step 3.

Authentication, tokens, and step-up

These profiles are co-design items with enterprise ICAM, because each depends on what the enterprise STS supports.

Token validation profile. Enforcement points accept only access tokens conforming to RFC 9068, never OIDC ID tokens. Validation covers issuer, token type, an algorithm allowlist, audience, expiry, not-before, and signing key rotation and caching, following RFC 8725 and RFC 9700. Service-to-service calls use sender-constrained tokens, through mTLS-bound tokens (RFC 8705) or DPoP (RFC 9449), as supported by the STS.

Delegation profile. Defines how the STS represents delegation versus impersonation, use of the actor claim where supported, client identity, audience, scope, actor authorization, and maximum delegation depth. Delegated actions are bounded by both the calling service's authority and the user's authority. RFC 8693 token exchange provides the mechanism; the profile defines the semantics.

Step-up protocol. When policy requires higher assurance, the response uses the RFC 9470 challenge (`insufficient_user_authentication`) with `acr_values` and `max_age`. Enterprise ICAM defines the `acr` values and their mapping to SP 800-63-4 assurance levels. The application sends the user through the enterprise STS, and the request is re-evaluated in full with the new token. Successful step-up never implies authorization by itself.

Authentication evidence and sender binding. Where policy depends on authentication strength or freshness, it requires verifiable evidence. `auth_time`, `acr`, and `amr` are mandatory for those decisions even though RFC 9068 makes them optional, and token issuance time is never treated as authentication time. Authentication time is preserved through refresh and token exchange, and maximum authentication age and allowed clock skew are defined per policy. Authentication assurance and federation assurance are evaluated separately under SP 800-63B-4 and SP 800-63C-4. Step-up challenges follow RFC 9470 HTTP semantics, and retries after step-up are idempotent, so a denied write never executes twice. For certificate-bound tokens, enforcement points verify the token's certificate confirmation, not merely the mTLS connection. For DPoP, they validate the proof's binding to the request and token, its age, the replay policy, and any required nonce at each hop. Trusted-proxy metadata is never accepted from outside the trust boundary. Workload-only identities are defined independently of interactive MFA.

Authorization surfaces

Authorization is not always one HTTP request. Every surface ultimately answers the same question, **can user X operate on object Y**, but the mechanism must fit the shape of the work. A search that returns 10,000 objects must not trigger 10,000 dual decisions, and it must not return 10,000 objects and filter them afterward.

The governing principle is **decide per subject, filter per object**. Subject-side constraints are computed once, then pushed down into the data store as a filter, so the store returns only what the user may see. Individual object decisions are reserved for small, bounded sets.

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Single action	Can Jane print this file?	One composed decision at the ingress or internal enforcement point	Decision on the request	Decision on the request
Interface rendering	Which actions can Jane take on the items on this page?	One batch evaluation for a bounded set	Batch decision	Batch decision
Search and listing	Which objects may Jane see?	Composed filter applied before the query runs	Subject-level ceiling plus every mandatory resource restriction in the envelope contract	Filter condition from the Cerbos query plan

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Exports and long-running jobs	May this job act on these objects for Jane?	Job runs under the delegation profile, applies the composed filter, and is re-evaluated before delivery and on relevant change events	Filter at selection; decision at delivery	Filter at selection; decision at delivery
Events and subscriptions	May Jane receive this stream of updates?	Decision at subscription; each message filtered by its authoritative attributes; subscriptions re-evaluated on change events	Subscription decision and message filter	Subscription decision and message filter
AI retrieval and agents	May this agent retrieve or act on this content for Jane?	Retrieval uses the composed filter before content reaches the model, including vector search through metadata pre-filtering; tool calls are decided like any other action	Same as search and actions	Same as search and actions

Surface	Question	Mechanism	Enterprise contribution	Mission contribution
Derived and cached data	Who may see a summary, index, or copy built from protected objects?	Derived artifacts inherit the most restrictive attributes of their sources and are filtered like the originals	Label inheritance rules	Mission tags carried forward

How search works

1. Composition obtains the enterprise contribution: the subject-level ceiling and every mandatory resource restriction defined in the applicable envelope contract, such as compartments and dissemination controls.
2. Composition obtains a query plan from Cerbos, such as case ID in Jane's assigned cases and not in any screened cases.
3. Both are combined into one filter and translated into the data store's native query, such as an Elasticsearch boolean filter.
4. The data store returns only permitted objects. Totals, pagination, facets, aggregations, highlights, suggestions, and similarity results are computed only from the filtered set.
5. If any mandatory restriction cannot be enforced before results or aggregates are produced, the query fails closed.

Requirements for collection surfaces

- **Filterability requirement.** Any mission rule that applies to a collection surface must be expressible as a filter for each registered data source. CI rejects policies whose query plans cannot be fully translated. Mandatory restrictions with no filter form are not permitted on collection surfaces.
- **No post-query evaluation of mandatory restrictions.** Post-query evaluation is limited to presentation refinements that do not affect what exists, such as which actions to display.
- **Objects carry authoritative attributes.** Every indexed object includes the attributes filters depend on, copied from the authoritative resource record and updated on reclassification.
- **Filters come from policy.** Filters are generated by the composition capability from the same policies that make individual decisions, never written by hand in applications.

- **Equivalence is proven per data source.** Automated tests compare generated filters with individual decisions across representative, adversarial, and aggregation cases.
- **Enforcement below the application.** Applications do not hold data store credentials that permit unfiltered queries. Queries pass through a filter-injecting data access layer, with document-level security in the data store as a backstop where available. Elastic's document-level security has documented limitations and licensing considerations; the OpenSearch security plugin is an open-source alternative to evaluate.

Continuous authorization and revocation

Enterprise ICAM and the mission will agree on a maximum exposure window for each revocation event. The design then meets those windows and the proof of concept measures them.

Event	Trigger	Exposure window	Mechanism
Account disabled	Enterprise IdP	To be set with ICAM	Token lifetime, session termination, shared signals if available
Clearance change	Personnel security system	To be set with ICAM	Authoritative lookup at decision time; cache invalidation
Mission removal or case reassignment	Mission entitlement service	To be set with the mission	Attribute change events invalidate cached decisions
Resource reclassification	Authoritative resource record	To be set with ICAM	Re-index; invalidate cached decisions for the resource
Policy update	Policy release	To be set with governance	Policy version included in every cache key
Device compromise	Endpoint management	To be set with ICAM	Shared signal or session termination

Cached decisions are keyed by subject, action, resource, context, policy version, and attribute versions. Sessions, long-running jobs, and subscriptions are interrupted or re-evaluated when a relevant event occurs.

Administrative controls

Administrative operations are separated by their safety properties. No control can broaden access without independent authorization.

Control	Effect	Who may invoke	Safety property
Emergency deny	Denies all access to a mission's protected resources	Enterprise ICAM or the mission	Always narrows; never widens
Policy rollback	Restores an earlier mission policy version, treated as a new policy change	Engineering governance board; enterprise ICAM approval required if effective access would expand	Validated against current envelopes and restrictions before release; emergency deny remains in place until validation completes; any expansion of access requires independent approval of its scope and duration
Break-glass exception	A governed policy exception, evaluated through composition, naming the subject, objects, actions, reason, and expiry	An independent authorizer designated by ICAM, separate from the requester and the mission	The only control that grants access; independently authorized, expiring, alerted, and reviewed; non-overridable enterprise controls still apply, and no decision point is switched off

Control	Effect	Who may invoke	Safety property
Decommission	Retires mission policy for a resource set	Enterprise ICAM, after verification	Permitted only once mission restrictions are migrated into enterprise policy or verified unnecessary

Reverting a mission to enterprise-only decisions is not an emergency action, because removing mission restrictions can widen access to objects they protected. For the same reason, previous approval of a policy version is evidence of historical review, not proof that it is safe under current attributes and envelopes.

Audit

Decision states. Composition normalizes each decision point's result to one of five states, each with a reason code: PERMIT; DENY; NOT_APPLICABLE, when no policy covers the request; ERROR, for a timeout or a malformed, incomplete, or invalid response; and NOT_EVALUATED, when evaluation was skipped because an earlier result already determined the outcome. An enterprise NOT_APPLICABLE is a coverage gap and denies. Batch responses are correlated item by item to their request tuples; a missing, duplicated, or unmatched item is an ERROR for that item, and actions that require every item to be permitted execute only if all are.

Two records, one correlation. Composition records its decision. The enforcement point separately records what it actually did: the action executed or refused, and each obligation's completion or failure. Both share the decision and correlation identifiers, so the audit trail distinguishes evaluated, skipped, failed, permitted, denied, and actually executed operations, and an intended permit is never recorded as an executed action.

Contents and protection. Records include enforcement point identity, policy versions, reason codes, attribute sources and versions, latency, and correlation ID. Audit transport is protected, integrity is preserved, retention follows enterprise requirements, and sensitive attribute values are minimized or referenced rather than copied. If the audit pipeline is unavailable, records are buffered durably at the source; protected actions that require an audit record are refused if it cannot be buffered.

What enterprise ICAM gains

- **Authority extended, not shared.** The enterprise decision is evaluated first and cannot be overridden by mission policy, fallbacks, or enforcement points.
- **New approval rights.** ICAM approves access envelopes, the composition truth table, administrative controls, mission adoption, and attribute promotion.
- **Safe emergency control.** ICAM can deny all access to any mission's protected resources at any time, a control that only ever narrows access.
- **More visibility than today.** Decision records show enterprise and mission outcomes for mission-level access ICAM cannot see today.
- **Lower request volume.** Fine-grained distinctions inside approved envelopes no longer arrive as individual entitlement requests.
- **Rogue authorization brought into the light.** Mission rules that today live in application code move into one governed, auditable pattern.

Ownership

Component	Owner	Responsibility
Enterprise STS and MFA	Enterprise ICAM	Authenticate users, issue tokens, perform step-up
Enterprise decision point	Enterprise ICAM	Clearances, attributes of record, enterprise policy floor
Composition truth table and administrative controls	Enterprise ICAM approves; platform team operates	Deterministic composition; emergency deny, rollback, break-glass, decommission
Authorization composition (Tyk plugin or dedicated service)	Platform team	Attribute retrieval, decision composition, filters, obligations, audit records
Tyk Gateway	Platform team	Ingress enforcement and token validation
Internal enforcement points	Product teams, using a shared library provided by the platform team	Enforcement for operations ingress cannot see

Component	Owner	Responsibility
Cerbos and mission policies	Mission data steward policy shop, implemented by mission engineering, approved through engineering governance	Mission, position, case, workflow, and step-up rules
Mission attribute and entitlement services	Mission data steward policy shop owns the data; platform team operates	Authoritative mission attributes such as case and role assignments
Applications	Product teams	Present tokens, honor decisions and obligations, carry no embedded authorization logic

The envelope model

Narrow-only composition means the mission layer cannot grant access the enterprise has not. New access is always an ICAM decision, expressed as an access envelope. ICAM approves envelopes through its existing process; inside them, the mission manages fine-grained distinctions as needs change.

The pattern distinguishes two kinds of change:

Kind of change	Example	Frequency	Decided by
Vocabulary change	Adding a new release marking or a new value to an enterprise attribute	Rare	Enterprise ICAM
Access change within an envelope	Allowing analysts assigned to a specific case to release its products	Frequent	Mission policy, through mission governance

Envelope contract. An envelope is not a ceiling alone. Each envelope is a structured, versioned record approved by ICAM, with these fields:

Field	Purpose
Subject population	Who the envelope covers, such as specific position codes within a mission
Permitted actions	The actions within scope, tiered so that high-impact actions such as release outside the organization can carry narrower terms
Resource scope	The data the envelope covers, such as one mission's data at or below a given marking
Exclusions	Resources or conditions explicitly outside the envelope
Required subject attributes	Attributes every covered subject must hold
Mandatory resource restrictions	Enterprise restrictions such as compartments and dissemination controls that must accompany every decision and every collection filter
Enforcement binding	The authenticated, registered enforcement points through which the envelope applies. Requests from any other path to layered mission resources are denied. An alternative path may reach those resources only if it demonstrably enforces all applicable enterprise and mission restrictions under the same approved protection model, or if the resources are an explicitly segregated set with a separately approved protection model. Enforcement point identity is established through authenticated workload identity, never a supplied identifier
Delegation	Whether and how services may act within the envelope on a user's behalf
Review date and version	When ICAM next reviews it, and which version is in force

Enterprise mandatory resource restrictions are evaluated on every single-object decision and included in every collection filter, so a broad envelope never authorizes an object those restrictions would deny.

Attribute governance

Every attribute has exactly one authoritative source, and every value used in a decision must be trustworthy, not merely well named.

Attribute trust tiers

Tier	Source	Trust basis	Example
1. Identity claims	Validated enterprise access token	Signature and token profile validation	User identity, authentication strength
2. Authoritative subject attributes	Enterprise or mission attribute service, queried by composition	Authenticated, integrity-protected call to the system of record; versioned	Clearance, position, case assignment
3. Authoritative resource attributes	Authoritative resource record, read by composition or the enforcement point	Read from the authoritative store, never from the request; security labels validated against the enterprise vocabulary	Classification marking, case ID
4. Caller-supplied context	The request	Untrusted	Client hints, display preferences

Tier 4 values are never used for security decisions. Missing mandatory attributes produce a deny. Every attribute used in a decision is recorded with its source and version, and reclassification of a resource propagates to its indexes and cached decisions.

Attribute catalog. The rows below are illustrative and will be confirmed against actual systems of record with ICAM during co-design.

Attribute	Category	Owner	System of record	Trust tier	Freshness	Usable by
User identity	Subject, of record	Enterprise ICAM	Enterprise IdP	1	Per token	Both decision points

Attribute	Category	Owner	System of record	Trust tier	Freshness	Usable by
Clearance and accesses	Subject, of record	Enterprise ICAM and security	Personnel security system	2	Authoritative at decision time	Enterprise decision point; mission read-only
Position assignment	Subject, of record	HR and personnel	Personnel system	2	On change	Both decision points
Authentication strength	Environment	Enterprise ICAM	Enterprise STS	1	Per token	Both decision points; mission for step-up
Access envelopes	Entitlement	Enterprise ICAM	Entitlement management system	2	On approval or revocation	Enterprise decision point
Classification markings	Resource	Vocabulary: enterprise security. Application: mission data steward policy shop	Authoritative resource record	3	On creation or reclassification	Both decision points
Mission data tag	Resource	Mission data steward policy shop	Authoritative resource record or data catalog	3	On change	Mission decision point
Mission role and cell membership	Subject, mission-derived	Mission data steward policy shop	Mission attribute service	2	On change	Mission decision point, restrictive rules only
Case assignment	Subject, mission-derived	Mission data steward policy shop	Case management system	2	On change	Mission decision point, restrictive rules only

Attribute	Category	Owner	System of record	Trust tier	Freshness	Usable by
Workflow or case state	Resource, mission-derived	Owning application	Authoritative application record	3	Per request	Mission decision point, restrictive rules only
Network zone and device posture	Environment	Platform team	Gateway and endpoint management	2	Per request	Both decision points

Governing rules:

1. **One owner per attribute.** If two parties can write the same attribute, it is not authoritative.
2. **The mission layer never writes or caches enterprise attributes** beyond versioned, invalidated decision caches.
3. **Mission-derived attributes only restrict.** They may narrow access inside an envelope but never stand in for a clearance or entitlement.
4. **Register before use.** Policies may reference only registered attributes. The registry generates Cerbos attribute schemas, so CI rejects policies that use unregistered or misnamed attributes.
5. **The attribute is enterprise; its interpretation is local.** Holding a position is an enterprise fact. What that position may do in a given mission is mission policy.

Enterprise vocabulary and mission vocabulary

The enterprise owns the vocabulary: which enterprise attributes exist, their allowed values, and what each value means. The data steward applies that vocabulary to the mission's own data and is accountable for labeling accurately. Each layer interprets labels for its own decisions, and the mission layer may only add conditions.

One test decides where an attribute lives: **does it need to mean the same thing outside this mission, or must the enterprise decision point evaluate it?** If yes, it is enterprise vocabulary, defined by the enterprise marking authority. If no, it is mission vocabulary, defined in the mission's namespace and never aliasing an enterprise term.

1. **Delegated sub-vocabularies.** The enterprise marking authority, or ICAM under an explicit delegation, may define a parent attribute and delegate management of its values to a mission, much as DNS delegates a subdomain.

2. **Provisional attributes.** A mission may define a new attribute in its namespace and use it immediately in restrictive rules, then nominate it for enterprise adoption.
3. **Predictable vocabulary changes.** Co-design establishes an agreed request process and expected turnaround for enterprise vocabulary changes.

The registry enforces these boundaries mechanically: enterprise attributes become fixed value lists in the Cerbos schemas, and mission attributes are validated against their namespace.

Responsibility matrix (RACI)

R: responsible for doing the work. A: accountable, exactly one per activity. C: consulted. I: informed.

Activity	Enterprise ICAM	Mission data steward policy shop	Mission engineering	Platform team	Engineering governance board	Product teams
Define marking vocabulary and taxonomy (enterprise marking authority; assignment to ICAM to be confirmed)	A, R	C	I	I	C	I
Maintain subject attributes of record	A, R	I	I	I	I	I
Approve mission adoption of the pattern	A, R	R	I	C	C	I
Request and justify access envelopes	C	A, R	C	I	I	C
Approve access envelopes and envelope contracts	A, R	C	I	I	C	I
Apply resource markings and mission tags	C	A	R	I	I	R
Define mission-derived attributes	C	A, R	C	I	C	I

Activity	Enterprise ICAM	Mission data steward policy shop	Mission engineering	Platform team	Engineering governance board	Product teams
Maintain the attribute registry	C	R	R	R	A	I
Author mission policy intent	I	A, R	C	I	I	C
Implement and test mission policies in Cerbos	I	A	R	C	I	I
Approve mission policy changes for release	C	R	C	I	A	I
Operate Tyk, composition, and Cerbos runtime	I	I	C	A, R	I	I
Change the composition truth table	A	I	I	R	C	I
Invoke emergency deny	A	R	I	R	I	I
Roll back mission policy	I	C	R	R	A	I
Authorize break-glass exceptions	A, R	I	I	C	I	I
Implement internal enforcement points	I	I	C	C	I	A, R
Integrate applications with the gateway	I	I	C	C	I	A, R
Review decision logs and audit	A	C	I	R	I	I
Register enforcement points, permitted actions, and obligation capabilities	C	C	I	A, R	I	R
Define and version the obligation profile	C	R	C	R	A	C

Marking vocabulary is shown under enterprise ICAM pending confirmation of the organization's actual marking authority, which may be a security or classification office. Whichever office holds it, any administration of the vocabulary by ICAM requires an explicit delegation. Separations of duty are deliberate. The data steward policy shop authors mission policy, but release approval sits with the governance board. The platform team operates the composition capability, but only ICAM can approve truth table changes or break-glass exceptions. During initial enforcement, ICAM also approves every mission policy.

Information flow and release

Release, print, export, re-distribution, and cross-mission flows are decided and enforced like any other action, with obligations such as watermarking returned by composition and honored by the enforcing application. Exports and transfers must pass through an enforcement point. Formal transfers between security domains are out of scope for this pattern and remain with the enterprise's existing cross-domain solutions.

Cross-mission attribute sharing

Other missions may need our mission-derived attributes alongside their own and the enterprise's. The governing principle is **share attributes, not policies**: other missions receive our facts and interpret them in their own policies, under the same narrow-only rule and enterprise ICAM oversight.

- **A governed attribute service.** Consuming missions call a read API through an enforcement point, authenticated with sender-constrained service tokens. The service enforces its own authorization, because attributes such as cell membership are sensitive in themselves.
- **Change events for consumers that cache,** with freshness expectations stated in the registry.
- **Not through the enterprise token** unless enterprise ICAM formally adopts the attribute.
- **Attributes versus decisions.** When another mission needs context for its own rules, we share the attribute. When the question is about our resources, the consumer calls the resource owner's governed composition endpoint, never a raw mission decision point. Composition determines every applicable mission from trusted resource ownership and provenance, never from caller preference, and requires enterprise

permission plus every required mission permission and obligation, so each relevant mission can cause a denial independently. Collection filters across missions are the intersection of each applicable mission's filter. The attribute service's own authorization uses a bounded, cycle-free bootstrap path that does not depend on the attributes it serves.

Governing rules: the registry is a versioned contract for shared attributes; consumers inherit the restrictive-only rule; each consuming mission is registered against the specific attributes it reads; and widely used attributes graduate to the enterprise catalog.

Activity	Enterprise ICAM	Providing mission's data steward policy shop	Consuming mission	Platform team	Engineering governance board
Define meaning and quality of a shared attribute	I	A, R	C	I	C
Approve a mission's access to shared attributes	C	A, R	R	I	I
Use shared attributes correctly in policy	I	C	A, R	I	I
Operate the attribute service and change events	I	C	I	A, R	I
Maintain the cross-mission attribute contract	C	R	C	I	A
Promote an attribute to the enterprise catalog	A, R	R	C	I	C

Anticipated objections and responses

Objection	Response
This creates a parallel IAM system.	The mission layer issues no identities, mints no tokens, and grants nothing. It refines access only within ICAM-approved envelopes, under one pattern ICAM governs.

Objection	Response
The mission layer could grant access the enterprise denied.	The enterprise decision is evaluated first, the truth table denies on every error or gap, and adversarial tests verify that no mission permit, fallback, or enforcement point can override an enterprise deny.
An emergency fallback could widen access.	Emergency deny only narrows. Rollback is validated against current restrictions and cannot expand access without independent approval. Break-glass is the only control that grants access, and it is a scoped, expiring exception evaluated through composition, never a bypass.
The gateway cannot see everything.	Tyk is the ingress enforcement point only. Internal enforcement points cover services, data, jobs, events, and AI tools, and bypass testing is a proof-of-concept gate.
Callers could forge attributes.	Security attributes come only from tokens, authoritative attribute services, and authoritative resource records. Caller-supplied values are never used.
We lose visibility.	ICAM gains visibility through decision records covering mission-level access it cannot see today.
This puts our ATO at risk.	No production use is proposed until the acceptance criteria are met, a threat model is accepted, and an independent assessment is complete. Control inheritance is claimed only after provider assessment.

Control mapping

A preliminary mapping to NIST SP 800-53 Rev. 5, to be validated with the ISSO and authorizing official. Enhancement selection varies with each system's baseline and tailoring.

Inheritance is an objective, not a current claim. Shared infrastructure can provide reusable controls, but complete inheritance depends on provider assessment, documented agreements, and authorizing official acceptance. The inheritance column uses three categories:

- **Candidate common:** intended to be provided by enterprise ICAM, the platform team, or the mission and inherited by product systems, pending provider assessment and acceptance.
- **Hybrid:** provided in part by the pattern, with a defined consumer obligation for each product team.
- **System-specific:** owned entirely by the product team.

A control is marked candidate common only where the provider supplies its entire scope with no consumer obligation. Any control with a product-team obligation is hybrid, and full inheritance applies only to the scope a provider demonstrably supplies.

Inheritance evidence. For each common or hybrid control, the provider and consumer responsibility matrix records the authorization boundary, implementation statement, parameter values, evidence, assessor, and the specific consumer duties. The mapping is pinned to NIST SP 800-53 Rev. 5 release 5.2.0 and to the organization’s selected baseline and tailoring, both to be confirmed by the ISSO. Representative product paths are walked to verify consumer controls, and inheritance is claimed only after the applicable authority accepts the evidence package; a crosswalk alone does not establish it.

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
AC-2 Account management	Enterprise accounts unchanged; mission entitlements carry approval, expiry, and recertification	Enterprise ICAM; mission	Hybrid	Manage any local or service accounts

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
AC-3 Access enforcement	Composed decision enforced at ingress and internal enforcement points	Platform team; product teams	Hybrid	Implement internal enforcement points for operations ingress cannot see
AC-3(7) Role-based access control	Mission roles evaluated in mission policy	Mission	Candidate common	None beyond AC-3
AC-3(8) Revocation of access authorizations	Revocation within agreed exposure windows; emergency deny	Enterprise ICAM; mission	Hybrid	Honor session, job, and subscription interruption
AC-3(9) Controlled release	Release decisions with mandatory obligations under a versioned obligation profile	Mission; product teams	Hybrid	Enforce returned obligations
AC-3(10) Audited override	Break-glass independently authorized, time-bound, alerted, reviewed	Enterprise ICAM; platform team	Candidate common	None
AC-3(13) Attribute-based access control	Decisions from governed, trust-tiered attributes	Enterprise ICAM; mission	Hybrid	Maintain authoritative resource attributes

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
AC-4 Information flow enforcement	Release, export, re-distribution, and cross-mission flows decided and enforced; cross-domain transfers use enterprise cross-domain solutions	Mission; platform team	Hybrid	Route exports and transfers through enforcement points
AC-5 Separation of duties	Separations in the RACI; workflow separations enforced in policy	Engineering governance board; mission	Hybrid	Model workflow states
AC-6 Least privilege	Envelopes narrowed by mission policy	Enterprise ICAM; mission	Hybrid	Least privilege for own service accounts and administrative functions
AC-6(7) Review of user privileges	Recertification of mission entitlements	Mission data steward policy shop	Candidate common	None
AC-6(9) Log use of privileged functions	Privileged actions and overrides recorded	Platform team	Candidate common	None
AC-16 Security and privacy attributes	Registry, trust tiers, label validation, inheritance, versioning, reclassification	Enterprise ICAM; mission	Hybrid	Label objects at creation; propagate attributes
AC-21 Information sharing	Governed cross-mission sharing	Mission	Candidate common	None

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
AC-24 Access control decisions	Deterministic composition with explicit failure states	Enterprise ICAM; mission; platform team	Candidate common	None
AC-25 Reference monitor	Composition and enforcement points always invoked, isolated, and tested for non-bypassability	Platform team; product teams	Hybrid	No bypass paths; constrained data store credentials
AU-2 and AU-12 Event logging and record generation	Normalized decision records from composition and separate enforcement records from every enforcement point	Platform team	Hybrid	Emit records from internal enforcement points through the shared library
AU-3 Content of audit records	Defined decision record schema	Platform team	Candidate common	None
AU-6 Audit review	ICAM reviews decision records; mission reviews divergence and overrides	Enterprise ICAM; mission	Candidate common	None
AU-9 Protection of audit information	Protected transport and integrity of decision records	Platform team	Candidate common	None
CA-7 Continuous monitoring	Decision records, divergence, policy drift detection, revocation testing	Platform team; enterprise ICAM	Candidate common	None

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
CM-3 Configuration change control	Tested, reviewed, approved policy releases with drift detection	Engineering governance board	Candidate common	None
CM-5 Access restrictions for change	Policy repository restricted to authorized authors	Platform team; engineering governance board	Candidate common	None
IA-2 Identification and authentication	Enterprise STS and MFA unchanged	Enterprise ICAM	Candidate common	None
IA-9 Service identification and authentication	Workload identity and mTLS between enforcement points, composition, decision points, and attribute services	Platform team; enterprise ICAM	Hybrid	Use issued workload identities
IA-11 Re-authentication	RFC 9470 step-up with ICAM-defined assurance values	Enterprise ICAM; mission	Hybrid	Handle step-up challenges
SC-8 Transmission confidentiality and integrity	mTLS protects all authorization traffic	Platform team	Candidate common	None
SC-16 Transmission of security attributes	Attributes from authoritative sources, carried on indexed objects	Platform team; product teams	Hybrid	Index required attributes

Control	How the pattern addresses it	Provider	Inheritance	Consumer obligation
SI-4 System monitoring	Decision records and overrides feed enterprise monitoring	Platform team; enterprise ICAM	Candidate common	None

Access control responsibilities product teams retain

Control	Product team responsibility
AC-2 Account management	Any local or service accounts the application creates; the goal is none beyond workload identities
AC-3 Access enforcement	Internal enforcement points for service calls, background jobs, and resolvers, calling the composition capability and applying generated filters
AC-3(9) Controlled release	Performing obligations under the obligation profile, and refusing the action when a mandatory obligation cannot be performed
AC-4 Information flow enforcement	Routing exports and transfers through enforcement points
AC-6 Least privilege	The application's own service accounts, data store credentials, and administrative functions
AC-8 System use notification	Banners where the application presents its own entry point
AC-12 Session termination	The application's own session handling; token lifetimes remain enterprise-controlled
AC-14 Permitted actions without identification	Declaring and justifying any unauthenticated endpoints; the goal is none
AC-16 Security and privacy attributes	Labeling objects at creation and carrying attributes into indexes, caches, and derived data

Control	Product team responsibility
AC-25 Reference monitor	Ensuring no path to protected data bypasses an enforcement point
AC-3(8) Revocation of access authorizations	Interrupting or re-evaluating sessions, jobs, and subscriptions when revocation events arrive
AC-3(13) Attribute-based access control	Maintaining authoritative resource attributes in the application's records
AU-2 and AU-12 Event logging and record generation	Emitting enforcement and obligation records from internal enforcement points through the shared library
IA-9 Service identification and authentication	Using issued workload identities and validating peers on every service-to-service call
IA-11 Re-authentication	Handling step-up challenges and making retries idempotent

Threat model summary

A full threat model is a Phase 0 deliverable, prepared with enterprise ICAM and security engineering. Its principal threats and mitigations:

Threat	Example	Primary mitigation
Enforcement bypass	A worker or analytics tool queries mission data directly	Complete mediation, constrained data store credentials, bypass testing
Attribute forgery	A caller supplies a false marking or case ID	Attribute trust tiers; resource attributes only from the authoritative record
Composition fault	An error or missing policy treated as permit	Deterministic truth table, fail closed, adversarial tests
Administrative widening	A fallback removes mission restrictions	Separated administrative controls

Threat	Example	Primary mitigation
Token misuse	Wrong issuer, wrong type, replayed, or ID token presented	Token validation profile; sender-constrained service tokens
Over-delegation	A service acts beyond the user's or its own authority	Delegation profile bounding both authorities
Search disclosure	Counts, facets, or similarity results reveal hidden objects	Filterability requirement; aggregates from filtered sets only
Stale authorization	A removed user keeps access	Agreed exposure windows; versioned, invalidated caches
Policy tampering	An unauthorized policy change reaches production	Restricted repository, approval gates, integrity-verified releases
Audit tampering	Decision records altered or lost	Protected transport, integrity, retention
Dependency outage	A decision point or attribute service is unavailable	Fail closed; high availability; tested recovery
Forged decision request	An enforcement point supplies a false user, role, or resource, or reuses one decision for another operation	Decision request binding profile; server-derived context; tuple-bound decisions
Obligation bypass	Content is released without a required watermark or redaction	Obligation profile; capability checked against registration; action refused on failure

Rollout

The rollout earns trust in stages. Enterprise ICAM holds emergency deny at every phase.

Phase	What happens	Enterprise ICAM role	Exit criteria
0. Co-design	ICAM, security engineering, the platform team, and the mission define the envelope contract, token and delegation profiles, step-up profile, revocation windows, audit schema, and threat model	Co-author	ICAM concurrence on profiles; threat model accepted
1. Proof of concept and shadow mode	Both composition options evaluated; ingress and internal enforcement points built for the pilot mission's data; Cerbos evaluates every request without enforcing	Reviews results and divergence reports	All acceptance criteria met; composition option selected; shadow divergence accepted
2. Limited enforcement	One mission, one use case, mission decisions enforced	Approves every mission policy; holds emergency deny	Independent assessment complete; pilot measures met
3. Steady state	Policy release approval moves to the governance board with ICAM sampling; additional missions adopt by ICAM decision	Samples policies; approves new missions and envelopes	Ongoing

Proof-of-concept acceptance criteria, adopted from the independent assessment with one addition:

Validation item	Minimum acceptance criterion
Decision composition	No enterprise denial or relevant evaluation error can yield a final permit
Emergency fallback	No emergency or rollback action makes access broader without independent approval. Rollback to a less restrictive predecessor remains blocked until approved; expired, overbroad, self-approved, and enterprise-forbidden break-glass requests are denied
Complete mediation	Every protected operation is covered, including direct service calls and asynchronous paths. With enterprise permit and mission deny, registered, unregistered, direct-service, and legacy paths to the same object all deny, and a spoofed enforcement point identity cannot select an envelope
Attribute trust	Manipulated, stale, or missing mandatory security attributes cannot authorize new access
Query equivalence	Generated filters and individual decisions agree across representative and adversarial cases, including aggregations
Token validation	Expired, forged, wrong-issuer, wrong-audience, and wrong-type tokens are rejected, as are wrong certificates, substituted keys, replayed proofs, and spoofed trusted-proxy metadata
Delegation and impersonation	Delegated service actions are bounded by both service and principal authority
Step-up	Required assurance and freshness are demonstrated; authorization is recalculated after step-up. Missing or unknown assurance evidence and stale authentication are rejected even with a fresh access token, and denied write retries do not execute twice

Validation item	Minimum acceptance criterion
Revocation	Agreed exposure windows are achieved for accounts, missions, policies, resources, and devices
Resilience	Enforcement point, composition, decision point, attribute service, network, and cache failures do not cause unauthorized permits
Audit evidence	Correlated decision and enforcement records, obligation outcomes, and policy versions are retained with appropriate protection. A complete state matrix for single and batch requests, including short, invalid, and reordered responses, shows no missing evaluation permits access
Performance	Latency, availability, capacity, and recovery objectives are defined and met for mission use cases
Shadow divergence	Divergence between mission decisions and current entitlements is reviewed and accepted by the mission and ICAM
Request binding	Forged subjects and actors, cross-tenant identifiers, caller-supplied roles or policy selectors, action substitution, unregistered actions, and replay of one resource's decision against another are rejected identically by both composition options
Obligations	With unknown, unsupported, conflicting, and deliberately failing mandatory obligations, no unprotected output leaves the enforcement point, and records distinguish the proposed permit, obligation completion or failure, and the action actually executed

Pilot priorities: adversarial composition and administrative control tests; Elasticsearch filter equivalence; backend bypass testing; token and delegation enforcement; and end-to-end revocation. The pilot also measures, against today's baseline, the time to deliver a

new rule inside an approved envelope and the volume of per-use-case entitlement requests reaching ICAM.

Why Tyk

- **Open source and self-hosted.** Tyk Gateway is released under MPL 2.0 and runs inside our environment. The exact components, editions, and dependencies deployed will be inventoried, because some Tyk code is commercially licensed.
- **Native identity handling.** OIDC and JWT validation are built in and can implement the token validation profile.
- **AuthZEN-ready.** An AuthZEN plugin makes Tyk a standards-based enforcement point for single-endpoint decisions.
- **Extensible middleware.** Plugins in Go, Python, JavaScript, or any gRPC-capable language provide the path for Option 1 composition.
- **Declarative operations.** Tyk Operator 1.0 is closed source and requires a license. Options are to license it, or to manage API definitions declaratively through CI against the open-source Gateway API.

Cerbos documents partial AuthZEN 1.0 support, covering metadata, evaluation, and batch evaluation; the search APIs are not assumed. Its native query planning supports collection filters through a separate, non-standard contract. A supported-capabilities matrix will be published for the pinned enterprise decision point, Cerbos, the Tyk plugin, and the composition API, and query planning, filter translation, and obligation handling will be kept in versioned extensions with adapter tests that verify enforcement is not weakened if an adapter or decision point is substituted. Integration of query plans, filter translation, and obligations with the chosen composition option is a design dependency to be demonstrated in the proof of concept.

What does not change

- The enterprise STS and MFA remain the sole source of identity.
- The enterprise decision service remains authoritative and is consulted first.
- Attributes of record, clearances, envelopes, and their approval processes remain with enterprise ICAM.

What gets better

- Mission rules ship at the mission's pace through reviewed, tested policy changes, inside boundaries ICAM sets.
- The bespoke auth proxy is retired in favor of standards-based enforcement.
- Enterprise ICAM sees more, approves the boundaries that matter, and fields fewer narrow requests.
- Applications are decoupled from any specific decision engine.

Risks and mitigations

Risk	Mitigation
Mission policy widens access by mistake	Truth table enforced in composition; enterprise evaluated first; policies tested in CI
Distributed enforcement scope grows beyond capacity	Complete mediation demonstrated for the pilot mission's data first, then extended by mission
Option 1 composition proves unworkable in the plugin	Option 2 provides the same semantics as a dedicated service
Added latency from two decisions	Enterprise first with short-circuit on deny; batch evaluation; latency objectives as acceptance criteria
Composition or gateway becomes a single point of failure	High availability; fail closed on errors
Plugin maintenance burden	Plugins built in CI against each gateway version
Business logic creeping into composition	Composition limited to retrieve, ask, combine, record; changes reviewed against that boundary
Licensing assumptions prove wrong	Component and edition inventory before the proof of concept

Decisions requested

1. Approve layered authorization as a target pattern in principle, subject to the corrections incorporated in this revision.
2. Charter an integrated security proof of concept including enterprise ICAM, security engineering, the platform team, and mission owners.
3. Designate an enterprise ICAM co-lead with approval authority over the truth table, envelope contracts, administrative controls, and phase gates.
4. Defer production authorization until the acceptance criteria are met, and make no claim of Zero Trust conformance or control inheritance until implementation, control assessment, and authorization evidence exist.

Open questions for co-design

- Does the enterprise decision service support query plans or partial evaluation, or only per-request decisions?
- Does it expose an AuthZEN interface, or will composition need an adapter?
- Which token types, sender constraints, and delegation semantics does the STS support today?
- Which acr values map to which SP 800-63-4 assurance levels?
- What revocation exposure windows does ICAM require for each event type?
- Does ICAM support CAEP or Shared Signals?
- What audit retention, transport, and integrity requirements apply to decision records?
- Who serves as the independent authorizer for break-glass exceptions?

Sources

- Independent architecture and security assessment, Layered Authorization, 7 October 2026 (internal)
- [NIST SP 800-207: Zero Trust Architecture](#)
- [NIST SP 800-207A: Zero Trust Architecture Model for Access Control in Cloud-Native Applications](#)
- [NIST SP 800-162: Guide to Attribute Based Access Control](#)
- [NIST SP 800-63-4: Digital Identity Guidelines](#)
- [NIST SP 800-53 Rev. 5: Security and Privacy Controls](#)

- [RFC 9068: JWT Profile for OAuth 2.0 Access Tokens](#)
- [RFC 8725: JSON Web Token Best Current Practices](#)
- [RFC 9700: Best Current Practice for OAuth 2.0 Security](#)
- [RFC 8693: OAuth 2.0 Token Exchange](#)
- [RFC 9470: OAuth 2.0 Step Up Authentication Challenge Protocol](#)
- [RFC 8705: OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens](#)
- [RFC 9449: OAuth 2.0 Demonstrating Proof of Possession \(DPoP\)](#)
- [OpenID Foundation: Authorization API 1.0 Final Specification approved](#)
- [Tyk Gateway repository and license](#)
- [Cerbos PDP v0.48 AuthZEN support](#)

Appendix: Glossary

Term	Definition
ABAC (attribute-based access control)	An access model in which decisions are made by evaluating attributes of the subject, resource, action, and environment against policy.
Access envelope	An ICAM-approved boundary defining what a population may do within a mission, recorded as an envelope contract. Mission policy refines access inside it and can never exceed it.
Administrative controls	The four separated operations that govern the pattern in exceptional situations: emergency deny, policy rollback, break-glass exception, and decommission.
Attribute	A fact used in an access decision, about a subject, a resource, or the environment.
Attribute of record	An attribute whose authoritative source is an enterprise system, such as identity, clearance, or position assignment.

Term	Definition
Attribute registry	The governed catalog of every attribute: owner, system of record, allowed values, trust tier, freshness, and permitted use.
Attribute trust tier	The classification of an attribute value by source: identity claims, authoritative subject attributes, authoritative resource attributes, or untrusted caller-supplied context.
Authentication strength	How strongly and how recently a user authenticated, carried in the token as assurance level and methods.
Authorization composition	The enterprise-governed capability that retrieves authoritative attributes, obtains enterprise and mission decisions, applies the truth table, handles obligations, and records the outcome. Implemented as a Tyk plugin (Option 1) or a dedicated service (Option 2).
AuthZEN	The OpenID Foundation Authorization API 1.0, defining single and batch evaluations, authorized subject, resource, and action search APIs, and discovery. It does not define policy query plans, data store filters, or the meaning of obligations.
Break-glass exception	A governed policy exception granting a named individual time-bound access to named objects and actions, evaluated through composition, authorized by an independent authorizer, alerted, and reviewed. Non-overridable enterprise controls still apply.
CAEP and Shared Signals	OpenID Foundation standards for sharing security events between systems in near real time.
Cerbos	The open-source decision engine (Apache 2.0) used as the mission decision point.

Term	Definition
Complete mediation	The principle that every protected operation passes through an enforcement point, with no bypass paths.
Composition truth table	The deterministic, ICAM-approved table that maps enterprise and mission outcomes to the effective decision, denying on every error or gap.
Confused deputy	A flaw in which a service with legitimate access is tricked into using it for a caller who lacks that access.
Correlation ID	A unique identifier that ties together all decision and enforcement records for one request.
Data steward policy shop	The mission team accountable for applying markings and tags, defining mission attributes, and authoring mission policy intent.
Decision outcome states	The five normalized outcomes recorded for each decision point: PERMIT, DENY, NOT_APPLICABLE, ERROR, or NOT_EVALUATED, each with a reason code. An enterprise NOT_APPLICABLE denies as a coverage gap.
Decision request binding	The profile that ties every decision to a verified subject, an authorized enforcement point, a canonical resource and version, a registered action, and server-derived security context, so a decision cannot be forged or replayed against another operation.
Delegated sub-vocabulary	An arrangement in which the enterprise marking authority, or ICAM under an explicit delegation, defines a parent attribute and delegates management of its values to a mission.

Term	Definition
Delegation profile	The co-designed rules for how services act on a user's behalf, distinguishing delegation from impersonation and bounding both authorities.
Emergency deny	The administrative control that denies all access to a mission's protected resources. It only ever narrows access.
Enforcement binding	The envelope contract field limiting an envelope to authenticated, registered enforcement points. Other paths to layered mission resources are denied.
Enterprise vocabulary	The enterprise-defined attributes and values with enterprise-wide meaning, such as classification and release markings.
Entitlement	A recorded approval giving a person or population a specific attribute or right.
Envelope contract	The structured, versioned record defining an access envelope's population, actions, scope, exclusions, required attributes, mandatory resource restrictions, enforcement binding, delegation, and review date.
Filterability requirement	The rule that any mission policy applying to a collection surface must translate into a data store filter, or it is rejected in CI.
ICAM (identity, credential, and access management)	The enterprise function responsible for identity, authentication, credentials, and enterprise access decisions.
Ingress enforcement point	The enforcement point at the edge of the environment that receives external requests. In this design, Tyk Gateway.

Term	Definition
Internal enforcement point	An enforcement point inside a service, data access layer, worker, event system, or AI tool interface, covering operations ingress cannot see.
JWT and OIDC	JSON Web Token, the signed token format the STS issues, and OpenID Connect, the authentication protocol built on it.
MFA (multi-factor authentication)	Authentication requiring more than one type of proof.
Mission layer	The mission-owned decision point, policies, and attributes.
Mission vocabulary	Attributes defined in a mission's namespace with meaning only within that mission.
Mission-derived attribute	An attribute owned by a mission, such as case assignment, usable only to restrict.
Narrow-only	The principle that the mission layer may add restrictions but never grant access the enterprise has denied.
Obligation	An instruction returned with a permit, such as applying a watermark, defined by the versioned obligation profile. A mandatory obligation that cannot be performed prevents the action; an advisory obligation may be skipped but is recorded.
PAP (policy administration point)	Where policies are written, reviewed, and managed.
PDP (policy decision point)	A component that evaluates policy and returns a decision. This design has an enterprise and a mission decision point.
PEP (policy enforcement point)	A component that intercepts an operation, obtains a decision, and enforces it. This design has ingress and internal enforcement points.

Term	Definition
PIP (policy information point)	A source queried for attributes, such as an enterprise lookup of clearances or the mission attribute service.
Policy rollback	The administrative control that restores an earlier mission policy version. It is treated as a new policy change, validated against current envelopes and restrictions, and cannot expand access without independent approval.
Provisional attribute	A new mission attribute used immediately in restrictive rules and later nominated for enterprise adoption.
Query plan	A condition returned by the mission decision point describing which resources a user may access, translated into a data store filter.
RACI	A responsibility matrix: Responsible, Accountable, Consulted, Informed.
Sender-constrained token	A token bound to its holder through mTLS or DPoP, so that a copied token cannot be used without the bound key and a successfully validated proof. It does not protect against compromised keys or implementation failures.
Shadow mode	A phase in which the mission decision point evaluates every request and records what it would decide, without enforcing.
Step-up authentication	Requiring a signed-in user to authenticate again, more strongly, before a sensitive action, using the RFC 9470 challenge.
STS (security token service)	The enterprise service that issues signed tokens and exchanges tokens for downstream services.
System of record	The single authoritative source for an attribute.

Term	Definition
Token exchange (RFC 8693)	A standard way to trade a token for a new one scoped to a downstream service.
Token validation profile	The co-designed rules every enforcement point applies when accepting a token.
Tyk Gateway	The open-source API gateway (MPL 2.0) used as the ingress enforcement point.
Zero Trust	A security model in which every access is decided per request based on identity, policy, and context, as described in NIST SP 800-207 and 800-207A.

Appendix: Revision history

Date	Revision
6 October 2026	Initial proposal

Date	Revision
7 October 2026	Revised to address the independent architecture and security assessment: adopted the recommended principal architecture claim; replaced the kill switch with separated administrative controls; introduced the authorization composition capability with two implementation options (Tyk plugin or dedicated service); repositioned Tyk as the ingress enforcement point and added internal enforcement points; removed the residual-page search fallback in favor of a filterability requirement and non-disclosure rules; added the envelope contract and attribute trust tiers; added token validation, delegation, step-up, revocation, and audit specifications as co-design items; corrected Tyk Operator licensing and AuthZEN scope statements; added SP 800-207A and SP 800-63-4 references and AC-4, AU-9, and SC-8; requalified control inheritance; added a threat model summary; adopted the assessment's acceptance criteria
7 October 2026, reassessment response	Resolved reassessment findings F-01 (unregistered paths now deny), F-02 (rollback treated as a policy change; break-glass as a governed exception), F-07 (cross-mission requests route through composition with intersecting missions), F-11 (five normalized decision states, batch correlation, separate enforcement records), F-12 (corrected AuthZEN scope and supported-capabilities matrix), F-13 (authentication evidence, freshness, and sender-binding profile), F-03 (decision request binding profile), F-04 (versioned obligation profile with mandatory enforcement semantics), and F-14 (hybrid reclassification of controls with consumer obligations, inheritance evidence requirements, pinned control catalog, SP 800-207 function mapping, and marking authority confirmation).